

Neighbour - CTF

[Kaynak](#) - [Yazar](#)

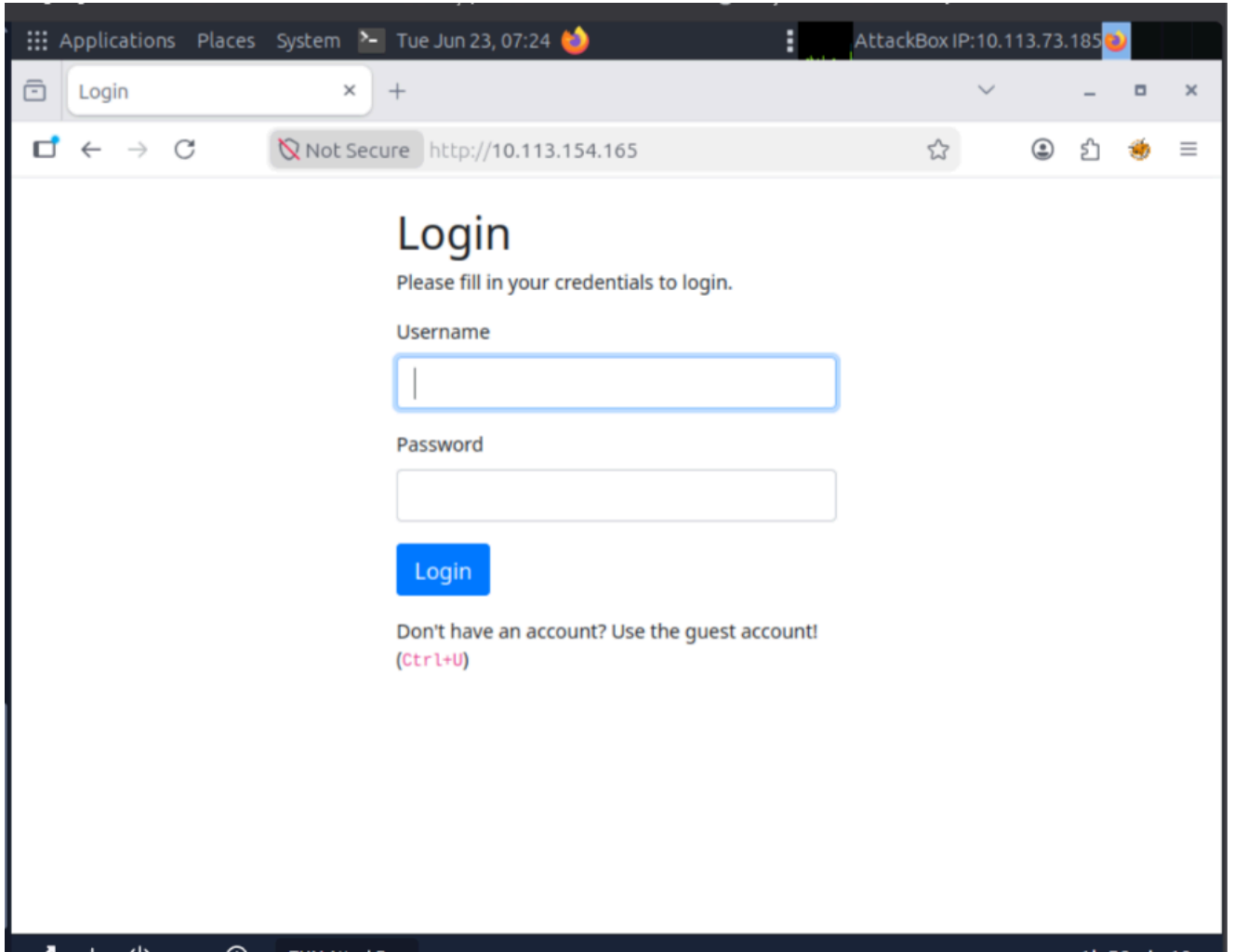
Hedef ve Ortam Bağlamı

Bu senaryoda, "Authentication Anywhere" adlı bir bulut hizmetini barındıran web uygulamasına yönelik sızma testi gerçekleştirilmektedir. Platformun mimarisi, kullanıcı profillerini barındırdığı için kimlik doğrulama (**Authentication**) ve yetkilendirme (**Authorization**) süreçlerinde mantıksal zafiyetler barındırma potansiyeline sahiptir.

Zafiyet Odağı: *IDOR* (Insecure Direct Object Reference - Güvensiz Doğrudan Nesne Referansı)

Keşif (Enumeration) ve Bilgi İfşası (Information Disclosure)

Sisteme erişim sağlamak ve saldırı yüzeyini haritalandırmak için öncelikle hedef IP adresi üzerinden sunulan HTTP servisini inceliyoruz. Karşımıza standart bir kullanıcı adı ve parola talep eden giriş sayfası çıkmaktadır.



Bu aşamada en kritik detay, sayfanın alt kısmında yer alan şu yönlendirmedir: *"Don't have an account? Use the guest account! (Ctrl+U)"*.

Bu mesaj, bize doğrudan bir ipucu vermektedir. Web tarayıcısında **Ctrl+U** kısayolu, o an aktif olan sayfanın **kaynak kod** dökümünü görüntülemek için kullanılır. Geliştiriciler sıklıkla test aşamasında bıraktıkları notları, geçici kimlik bilgilerini veya yorum satırlarını canlı ortama (production) taşıyarak kritik yapılandırma hataları yaparlar. Bu zafiyet türü literatürde **Information Disclosure** (Bilgi İfşası) olarak adlandırılır.

Sayfanın kaynak kodunu manuel olarak incelemek yerine, terminal üzerinden **curl** aracı ile sayfa içeriğini çekip otomatik bir filtreleme işlemi gerçekleştiriyoruz:

```
curl -s http://10.113.154.165 | grep -i "guest"
```

Bu kodun teknik açılımı şöyledir;

- **curl** aracı hedef sunucuya bir HTTP GET isteği gönderir
- **-s (silent)** parametresi, aracın indirme yüzdesi veya hız gibi gereksiz istatistiksel çıktılarını gizleyerek terminalin temiz kalmasını sağlar.

Böylelikle elde edilen veri raw yani ham HTML çıktısı, **|** pipe operatörü ile **grep** aracına aktarılır. **-i** parametresi ile büyük/küçük harf duyarlılığı olmadan içinde "guest" kelimesi geçen spesifik satırlar yakalanır.

HTML yorum satırları arasına (`<!-- ... -->`) gizlenmiş olan geçici kimlik bilgilerine ulaşılır. Geliştirici, `guest:guest` şeklinde test hesabı bilgilerini doğrudan istemci tarafına (client-side) ifşa etmiş ve `admin` hesabının yasaklı olduğunu belirterek sistemde yetkili bir yönetici hesabının varlığını (**Username Enumeration** - Kullanıcı Adı Keşfi) kanıtlamıştır.

```
2 <!DOCTYPE html>
3 <html lang="en">
4 <head>
5   <meta charset="UTF-8">
6   <title>Login</title>
7   <link rel="stylesheet" href="https://stackpath.bootstrapcdn.com/bootstrap/4.5.2/css/bootstrap.min.css">
8   <style>
9     body{ font: 14px sans-serif; }
10    .wrapper{ width: 360px; padding: 20px; margin: 0 auto; }
11  </style>
12 </head>
13 <body>
14   <div class="wrapper">
15     <h2>Login</h2>
16     <p>Please fill in your credentials to login.</p>
17
18     <form action="/index.php" method="post">
19       <div class="form-group">
20         <label>Username</label>
21         <input type="text" name="username" class="form-control" value="">
22         <span class="invalid-feedback"></span>
23       </div>
24       <div class="form-group">
25         <label>Password</label>
26         <input type="password" name="password" class="form-control">
27         <span class="invalid-feedback"></span>
28       </div>
29       <div class="form-group">
30         <input type="submit" class="btn btn-primary" value="Login">
31       </div>
32       <p>Don't have an account? Use the guest account! (<code>Ctrl+U</code>)</p>
33       <!-- use guest:guest credentials until registration is fixed. "admin" user account is off limits!!!! -->
34     </form>
35   </div>
36 </body>
37 </html>
```

İlk Erişim (Initial Access) ve Oturum Analizi

Elde ettiğimiz **guest** kimlik bilgilerini kullanarak login formu üzerinden sisteme kimlik doğrulama işlemini gerçekleştiriyoruz. Başarılı bir girişin ardından uygulamanın bizi yönlendirdiği URL yapısı ve ekrandaki profil bilgileri, bir sonraki saldırı vektörümüzün temelini oluşturmaktadır.

Giriş yaptıktan sonra tarayıcının adres çubuğundaki URL şu yapıya dönüşmektedir:

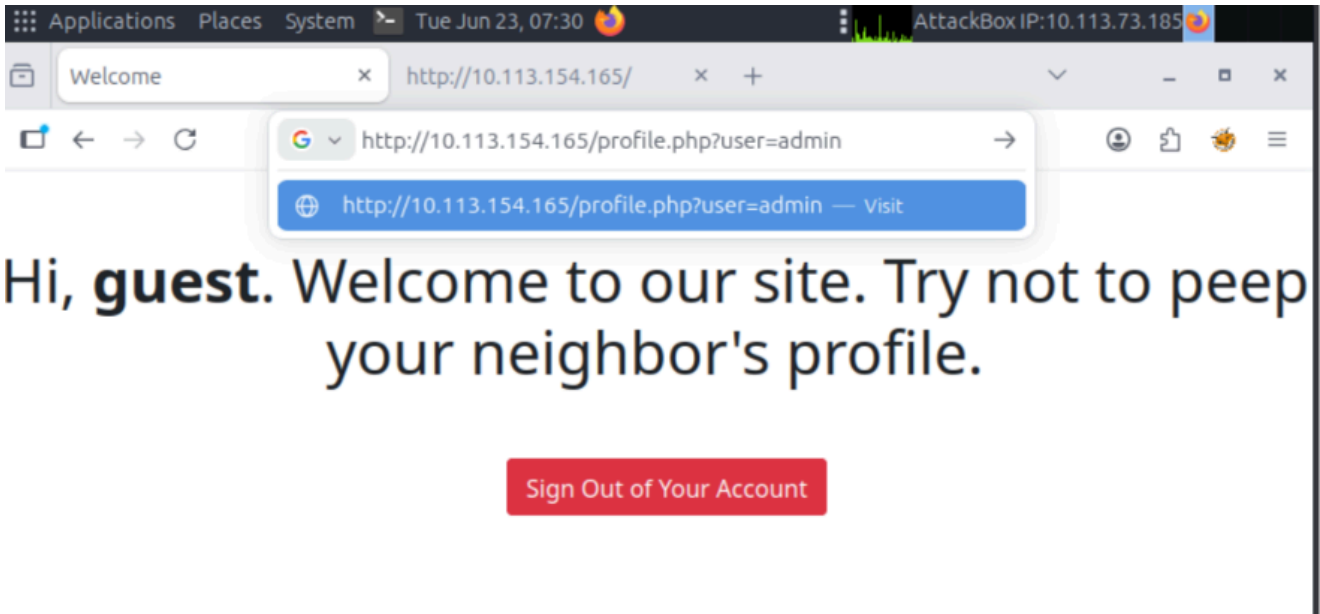
```
http://10.113.154.165/profile.php?user=guest
```

Buradaki **user** parametresi, uygulamanın arka plandaki veritabanından hangi kullanıcının verilerini çekeceğini belirleyen bir girdi noktasıdır (**Input Vector**).

ÖNEMLİ: Zafiyetin mimari temeli tam olarak bu noktada yatmaktadır. Uygulama, **user=guest** parametresini alırken kullanıcının gerçekten o profile erişim yetkisi olup olmadığını sunucu tarafında (Server-side) kontrol etmemektedir. Eğer web uygulaması sadece istemciden (client) gelen parametreye güvenerek veritabanı sorgusu çalıştırıyor ve veriyi döndürüyorsa, sistemde **IDOR** zafiyeti mevcut demektir.

IDOR (Insecure Direct Object Reference) Sömürüsü (Exploitation)

Platformun açıklamasındaki *"Başka insanların profillerindeki sırları bulamazsınız, değil mi?"* şeklindeki detay ve "Neighbour" (Komşu) konsepti, sömürü rotamızı netleştirmektedir. Kendi profilimiz (**guest**) yerine, sistemdeki başka bir hesaba, spesifik olarak kaynak kodda varlığını tespit ettiğimiz sistem yöneticisine (**admin**) geçiş yapmalıyız.



URL üzerindeki parametreyi manipüle ederek yatay/dikey **Privilege Escalation** (Ayrıcalık Yükseltme) vektörünü tetikliyoruz. `guest` değerini silip yerine `admin` yazarak sunucuya yeni bir istek gönderiyoruz:

```
http://10.113.154.165/profile.php?user=admin
```

Bu HTTP GET isteği sunucuya ulaştığında arka planda gerçekleşen olay şudur: Sunucu, oturum açan kişinin yetki seviyesini (**Authorization**) doğrulamadan, doğrudan `user` parametresinde belirtilen **admin** değerini veritabanı sorgusuna dahil eder. Yetki kontrolü eksikliği nedeniyle veritabanı "admin" profiline ait verileri çeker ve uygulama bu verileri HTTP 200 OK yanıtıyla birlikte ekrana basar.

Sayfa yüklendiğinde, yetkilendirme mekanizmasının çökmesi (**Broken Access Control**) sonucu hedef yöneticinin profiline yetkisiz erişim sağlamış oluruz. Ekranda, yöneticinin profilinde gizlenmiş olan CTF bayrağı (Flag) açık metin (clear-text) olarak görüntülenir.

DİKKAT: Eğer **admin** kullanıcı adı çalışmasaydı (örneğin veritabanında böyle bir kullanıcı gerçekten var olmasaydı sistem boş bir sayfa veya HTTP 404 Not Found hatası dönerdi), metodolojimizdeki B planını devreye sokmamız gerekirdi. Bu senaryoda **Burp Suite** proxy aracının **Intruder** modülünü kullanarak `user=` parametresine popüler kullanıcı adlarından oluşan geniş bir kelime listesi (**Wordlist** - örneğin SecLists kütüphanesinden `names.txt`) vererek **Fuzzing** (otomatize deneme yanılma ve girdi manipülasyonu) işlemi gerçekleştirmeli ve geçerli yanıt dönen farklı "komşu" hesapları tespit etmeliydik. Ancak bu spesifik senaryoda, kaynak kod analizinden elde edilen istihbarat ile doğrudan hedefe ulaşılmıştır.